



AB Bank Rwanda Review 2025

Contents

1. EXECUTIVE SUMMARY	2
2. OVERVIEW OF EXISTING WORKSPACE	3
2.1. SUMMARY OF ACTIVE ANALYTIC RULES	3
2.2. AVAILABLE LOG TABLES IDENTIFIED	4
3. THREAT LANDSCAPE ANALYSIS	5
3.1. PRIMARY THREAT ACTORS	5
3.2. KEY ATTACK VECTORS	6
3.3. EMERGING THREATS	6
4. RECOMMENDATIONS	7
4.1. EXISTING DETECTION RULES REQUIRING OPTIMIZATION	7
4.2. RECOMMENDED RULES MAPPED TO MITRE ATTACK	8
4.3. OPERATIONAL RECOMMENDATIONS	11
5. CONCLUSION	11

1. Executive Summary

This report presents an assessment of the Access Bank Rwanda environment, with the objective of evaluating existing detection coverage, identifying gaps, and recommending targeted improvements aligned with the MITRE ATT&CK framework. The review focuses on analytic rule coverage, available telemetry sources, and the organization's ability to detect and respond to threats relevant to the financial services sector.

The assessment indicates that the current Sentinel deployment benefits from a strong telemetry foundation and mature baseline detections. Optimal coverage has been achieved across several critical attack stages, including Initial Access and Persistence, supported by extensive identity, endpoint, network, and security operations logging. This provides the organization with solid visibility into common attack techniques and supports effective security monitoring and investigation.

However, the review also identified opportunities to further enhance detection maturity. Coverage for tactics such as Lateral Movement, Reconnaissance, Resource Development, Collection, and Impact remains limited, and several existing analytic rules would benefit from optimization to reduce false positives, improve contextual accuracy, and better reflect real-world attacker behavior. Addressing these gaps is essential to improving detection of advanced and multi-stage attacks.

To address these findings, the report recommends a combination of targeted rule tuning, deployment of additional MITRE ATT&CK-mapped analytic rules, and continued operational enhancements aligned to a SOC maturity model. Implementing these recommendations will strengthen threat detection capabilities, improve incident prioritization and response effectiveness, and ensure continued alignment with industry best practices and regulatory expectations.

Overall, the findings demonstrate that Access Bank Rwanda is well-positioned to build upon its existing security monitoring capabilities. By implementing the recommended enhancements, the organization can further improve resilience against evolving cyber threats while maintaining a robust, scalable, and audit-ready security operations posture.

2. Overview of Existing Workspace

2.1. Summary of Active Analytic Rules

The table below summarizes the organization's detection coverage mapped to the MITRE ATT&CK framework. It lists each attack tactic with its corresponding MITRE tactic ID, the number of detection rules in place, and an overall coverage level.

The detection rule count indicates the extent of monitoring for each tactic, while the coverage level provides a qualitative assessment of detection strength, highlighting areas of strong visibility and potential gaps. Overall, the table offers a concise view of detection maturity across the attack lifecycle and supports prioritization of security improvements.

Workspace: ABR-sentinel-workspace **Active Rules:** 357

MITRE ATT&CK Tactic	Tactic ID	Detection Rules Count	Coverage Level
Initial Access	TA0001	83	Optimal
Persistence	TA0003	79	Optimal
Privilege Escalation	TA0004	28	Medium
Defense Evasion	TA0005	50	High
Credential Access	TA0006	46	Medium
Discovery	TA0007	27	Medium
Lateral Movement	TA0008	13	Low
Reconnaissance	TA0043	6	Low
Resource Development	TA0042	2	Low
Execution	TA0002	30	Medium
Collection	TA0009	14	Low
Command And Control	TA0011	59	High
Exfiltration	TA0010	18	Medium
Impact	TA0040	27	Medium

Sensitivity: COMMERCIALY CONFIDENTIAL

2.2. Available Log Tables Identified

LogManagement	Microsoft Sentinel	Security and Audit
AADManagedIdentitySignInLogs	AlertEvidence	ProtectionStatus
AADNonInteractiveUserSignInLogs	AlertInfo	SecurityAlert
AADRiskyUsers	Anomalies	SecurityBaseline
AADServicePrincipalSignInLogs	DeviceEvents	SecurityBaselineSummary
AADUserRiskEvents	DeviceFileCertificateInfo	SecurityEvent
AuditLogs	DeviceFileEvents	SecurityNestedRecommendation
AzureActivity	DeviceImageLoadEvents	SecurityRecommendation
AzureDiagnostics	DeviceInfo	SecurityRegulatoryCompliance
AzureMetrics	DeviceLogonEvents	Update
Event	DeviceNetworkEvents	
Heartbeat	DeviceNetworkInfo	
MicrosoftGraphActivityLogs	DeviceProcessEvents	
Operation	DeviceRegistryEvents	
Perf	EmailAttachmentInfo	
SignInLogs	EmailEvents	
Syslog	EmailPostDeliveryEvents	
Usage	EmailUrlInfo	
	IdentityDirectoryEvents	
	IdentityLogonEvents	
	IdentityQueryEvents	
	OfficeActivity	
	SecurityAlert	
	SecurityEvent	
	SecurityIncident	
	ThreatIntelIndicators	
	ThreatIntelligenceIndicator	
	ThreatIntelObjects	
	UrlClickEvents	
	Watchlist	

SecurityCenterFree	Microsoft Sentinel UEBA	Custom Logs
ProtectionStatus	BehaviorAnalytics	WsSecurityEvents_CL
SecurityAlert	IdentityInfo	
SecurityBaseline	UserPeerAnalytics	
SecurityBaselineSummary		
SecurityNestedRecommendation		
SecurityRecommendation		
SecurityRegulatoryCompliance		
Update		

The log tables listed above were identified as available within the workspace and represent the telemetry currently supporting Microsoft Sentinel detections and investigations. They provide coverage across identity and access activity (Azure AD), endpoint and alert telemetry (Defender for Endpoint), email and collaboration signals (Exchange/Office/URL events), infrastructure and network logging (Azure diagnostics, Syslog, Heartbeat, Perf), and SOC operations data (alerts, incidents, threat intelligence, UEBA, and watchlists), including WithSecure custom logs. Overall, this breadth of log coverage provides a strong foundation for comprehensive detection, correlation, and effective security operations across the environment.

3. Threat Landscape Analysis

Financial institutions in 2025 face a rapidly evolving cyber threat landscape driven by sophisticated actors, increased digitalization, and widespread adoption of mobile and cloud financial services.

3.1. Primary Threat Actors

- Nation-state APT groups (e.g., Lazarus) targeting banks, fintechs, and crypto exchanges for large-scale theft and espionage. Notable 2025 incidents include the \$1.5B Bybit and \$30M Upbit crypto heists.
- Organized cybercriminal groups operating Ransomware-as-a-Service (RaaS), Business Email Compromise (BEC) syndicates, and fraud networks. Groups like LockBit and BlackCat continue global operations; African-origin fraud networks (e.g., Black Axe) remain highly active.

3.2. Key Attack Vectors

- **Phishing & Social Engineering:** Still the dominant initial access vector, responsible for the majority of breaches. AI-generated phishing and deepfake-assisted BEC significantly increase attack success rates.
- **Ransomware:** Persistent threat with rising frequency. Attacks target both major financial institutions and smaller banks, often using double/triple extortion tactics.
- **Supply Chain Attacks:** Compromise of third-party providers (core banking software, file transfer systems, ERP modules) leading to multi-institution breaches.
- **Vulnerability Exploitation:** Rapid weaponization of newly disclosed CVEs and continued use of zero-days by APT groups. Public-facing apps and VPNs remain prime targets.
- **Credential Theft:** Infostealers, session token theft, and phishing-harvested credentials now rival vulnerabilities as the most common intrusion vector.
- **DDoS Attacks:** Used for extortion or as smokescreens; financial services remain among the top targeted industries.

3.3. Emerging Threats

- **AI-Driven Attacks:** Automated phishing, impersonation (voice/video deepfakes), malware generation, and large-scale credential testing enabled by adversarial AI.
- **Mobile and Fintech Attacks:** Growth of ATS-enabled mobile banking trojans, SIM swap fraud, NFC payment abuse, and fake banking apps—especially prevalent in Africa and Asia.
- **Cryptocurrency & DeFi Exploitation:** Theft through exchange compromise, private key theft, and smart contract vulnerabilities; criminal use of blockchain for resilient command-and-control (C2).
- **Automation & Crimeware-as-a-Service:** Ready-made phishing kits, access brokerage, automated exploitation frameworks reduce the skill barrier and increase attack scale.

4. Recommendations

The recommendations provided in this report align with a progressive SOC maturity model, enabling phased improvement based on capability and resource availability. This maturity-based approach ensures that detection improvements are sustainable, measurable, and aligned with the organization's operational readiness.

4.1. Existing Detection Rules Requiring Optimization

This section highlights detection rules that are currently active within the environment but require refinement to improve their effectiveness and reliability. While these rules provide baseline visibility into potential security events, some may generate excessive false positives, lack sufficient contextual enrichment, or rely on broad conditions that reduce detection accuracy.

Rules	Description	Suggested Optimization
Withsecure Security event	Vendor security events from WithSecure.	Add tuning for known safe apps and/or exclude "blocked" Application Control events.
WithSecure EDR And Browser - High Risk	Detects all high-risk detections/BCDs from WithSecure.	Split into two rules: (1) Browsing Protection: trigger only on allowed connections to malicious domains (and consider adding repeat threshold like ≥ 2 hits in 10 mins). (2) EDR detections: trigger for EDR detections.
AD Account Lockout	Detects Active Directory account lockouts	Currently have two concurrent rules, disable one to prevent duplicate alerts. Add a threshold/aggregation (e.g., ≥ 5 lockouts for same user in 15 mins OR ≥ 20 lockouts org-wide in 10 mins).

Machine changes	Detects user or computer account modifications.	Increase threshold to >3 changes within a time window (e.g., 3 changes in 10 mins). Split by object type (user vs computer) and alert for high-risk changes (e.g., Domain Admin membership, SPN changes, userAccountControl flags, adminCount, delegation settings).
------------------------	---	---

4.2. Recommended Rules mapped to MITRE ATTACK

The recommended analytic rules mapped to the MITRE ATT&CK framework enhance the organization's ability to detect and respond to common adversarial behaviours that lead to security incidents.

These rules leverage Syslog and native telemetry to identify abnormal activity, misuse of legitimate services, and repeated unauthorized actions using behaviour-based detection rather than signatures. It is recommended that detection coverage be expanded in lower-visibility tactics and that rules be regularly reviewed and tuned to improve accuracy.

Mapping detections to MITRE ATT&CK improves threat visibility, enables effective event correlation across the attack lifecycle, and supports timely, prioritized incident response in alignment with industry-recognized threat models.

- **Persistence**

- **Detect logon scripts (T1037)**

Source: Windows Security Event Logs

Description: Monitors execution of logon scripts used to re-establish access after user authentication.

- **Detect startup modifications (T1547)**

Source: Microsoft Defender for Endpoint

Description: Identifies changes to startup folders, registry run keys, or services used for persistence.

- **Identify malicious browser plugins (T1176)**

Source: Microsoft Defender for Endpoint / Browser Telemetry

Description: Detects suspicious or unauthorized browser extensions that enable persistent access.

- **Privilege Escalation**

- **Alert on token manipulation (T1134)**

Source: Microsoft Defender for Endpoint

Description: Detects manipulation or theft of access tokens to impersonate privileged users.

- **Defense Evasion**

- **Detect permission changes (T1222)**

Source: SecurityEvent

Description: Monitors unauthorized file or directory permission modifications.

- **Detect policy modifications (T1484)**

Source: SecurityEvent

Description: Identifies suspicious changes to domain or group policies.

- **Detect process hollowing (T1055)**

Source: Microsoft Defender for Endpoint

Description: Detects process injection techniques used to evade detection.

- **Collection**

- **Detect access to sensitive files (T1005)**

Source: Microsoft Defender for Endpoint

Description: Monitors to access sensitive local files indicating data collection.

- **Monitor clipboard capture (T1115)**

Source: Microsoft Defender for Endpoint

Description: Detects malicious processes accessing clipboard data.

- **Detect screen capture tools (T1113)**

Source: Microsoft Defender for Endpoint

Description: Identifies unauthorized screen capture activity.

- **Lateral Movement**

- **Monitor SMB transfers (T1021.002)**

- Source:** Windows Security Event Logs / Defender for Endpoint

- Description:** Detects lateral movement via SMB or administrative shares.

- **Detect removable media replication (T1091)**

- Source:** Microsoft Defender for Endpoint

- Description:** Identifies malware spreading through removable media between hosts.

- **Discovery**

- **Detect password policy discovery (T1201)**

- Source:** Windows Security Event Logs

- Description:** Detects enumeration of password and account policies.

- **Detect file and directory discovery (T1083)**

- Source:** Microsoft Defender for Endpoint

- Description:** Monitors reconnaissance of file systems.

- **Detect Group Policy discovery (T1482)**

- Source:** Windows Security Event Logs

- Description:** Identifies reconnaissance of domain and group policies.

- **Identify network share mapping (T1135)**

- Source:** Windows Security Event Logs

- Description:** Detects discovery of shared network resources.

- **Impact**

- **Monitor deletion of critical files (T1485)**

- Source:** Microsoft Defender for Endpoint

- Description:** Detects destructive deletion of sensitive or critical data.

- **Detect backup destruction (T1561)**

- Source:** Microsoft Defender for Endpoint

- Description:** Alerts when backups are deleted or tampered with.

4.3 Operational Recommendations

- Update and Maintain Microsoft Sentinel Watchlists
- Use known baselines per service to reduce false positives.
- Tie high-severity alerts to automated isolation playbooks (EDR) for critical servers.
- Enrich alerts with Threat Intelligence and recent build/patching data.
- Maintain a privileged account inventory and require MFA for any privileged role changes.
- Implement automated firewall blocks for repeated external brute force sources and suspicious IPs.
- Ensure logging redundancy, multiple collectors for FortiGate and syslog devices and alert collectors dropping data.

5. Conclusion

This assessment confirms that Access Bank Rwanda has implemented a mature Microsoft Sentinel deployment with strong foundational detection capabilities and extensive log coverage across identity, endpoint, email, network, and security operations telemetry. The current environment demonstrates **optimal coverage** across several critical MITRE ATT&CK tactics, particularly Initial Access and Persistence, supported by a robust set of analytic rules and diverse telemetry sources, including Microsoft Defender, Azure AD, Syslog, and WithSecure EDR data.

The review also identified areas where detection effectiveness can be further enhanced, particularly across tactics such as Lateral Movement, Reconnaissance, Resource Development, and Collection, where coverage remains limited or uneven. In addition, several existing analytic rules would benefit from targeted optimization to reduce alert noise, improve contextual accuracy, and better align detections with real-world attacker behavior and operational workflows.

The recommended MITRE ATT&CK-mapped analytic rules and optimization actions provide a structured, intelligence-driven path to closing these gaps while maintaining SOC efficiency and audit readiness. By adopting a phased, maturity-based approach to implementation, combining rule tuning, behavioral detection, and continuous review, Access Bank Rwanda can strengthen its ability to detect advanced threats, reduce response times, and better protect critical systems and sensitive data.

Overall, continued alignment of detection strategy with the MITRE ATT&CK framework, coupled with the organization's strong telemetry foundation, positions the bank to proactively manage cyber risk, adapt to evolving threat landscapes, and sustain a resilient and effective security operations capability.